

TLP:CLEAR

БЕС через скомпрометированный ящик НКО + AiTM-кит Tycoon 2FA

Thread hijacking, злоупотребление Microsoft Customer Voice и многослойная AiTM-инфраструктура

БЕС | Thread Hijacking | AiTM | Tycoon 2FA | Microsoft 365 | PaaS Phishing

Параметр	Значение
Дата инцидента	11 мая 2026, 21:22 UTC
Дата анализа	12 мая 2026
Классификация	TLP:CLEAR
Уровень угрозы	ВЫСОКИЙ
Тип	БЕС / Thread Hijacking / AiTM Phishing / PaaS Phishing Kit
Тема письма	FW: ACH Submission Attached
Домен отправителя	unapei-ap.fr (скомпрометированный M365-ящик)
Домен получателя	zenpulsar.com (финансовый ящик, Google Workspace)
Ссылка-приманка	hxxps://nam[.]dcv[.]ms/o9XDteis3W (Microsoft Customer Voice)
IP финальной стадии	198[.]23[.]210[.]61 (RackNerd / ColoCrossing, США)
Семейство кита	Tycoon 2FA / Mamba 2FA (Storm-1575)

1. Краткая сводка

11 мая 2026 года фишинговое письмо высокой степени достоверности было доставлено с реального Microsoft 365-ящика домена unapei-ap.fr (французская НКО UNAPEI Alpes Provence) на финансовый адрес домена zenpulsar.com. Письмо прошло через подлинные серверы исходящей почты Exchange Online — это компрометация аккаунта, а не подделка адреса.

Атака использует три уровня обхода защиты. Первый: отправляющий аккаунт настоящий, письмо отправлено через легитимные серверы M365 и проходит проверки SPF/DKIM/DMARC. Второй: письмо встроено в реальную переписку из взломанного почтового ящика на французском языке — медицинское обсуждение — чтобы создать контекстную легитимность для антифишинговых фильтров. Третий: единственная ссылка в письме ведёт через легитимный сервис Microsoft (Customer Voice / Forms Pro, nam.dcv.ms), который включён в белые списки большинства корпоративных шлюзов.

Конечная цель — AiTM-кит (Adversary-in-the-Middle) семейства Tycoon 2FA / Mamba 2FA, размещённый на VPS в США. Кит показывает поддельную страницу входа Gmail/Google, фильтрует ботов и сканеры через XOR-обфусцированный API-

запрос и похищает учётные данные и сессионные куки для обхода MFA. Выявлен кластер минимум из семи параллельных фишинговых доменов на одном IP-адресе, все сертифицированы 17 апреля 2026 года.

2. Хронология атаки

Дата/время (UTC)	Событие
2018-06-25	Регистрация легитимного домена unapei-ar.fr. Владелец: UNAPEI Alpes Provence, Франция.
2026-04-17	Выпуск сертификатов Let's Encrypt для всех 7 фишинговых доменов кластера (stiofidri.company и 6 параллельных) — за 3–4 недели до атаки.
2026-05-11 14:50:51	Создание формы Microsoft Customer Voice со скомпрометированного M365-аккаунта домена unapei-ar.fr. Заголовок: «A SECURED FILED HAS BEEN SUCCESSFULLY SHARED WITH YOU!»
2026-05-11 14:54:26	Финализация формы; ссылка-payload установлена на hxxps://stiofidri[.]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/
2026-05-11 ≤21:22	Компрометация M365-ящика в домене unapei-ar.fr (вектор: вероятно, предшествующий AiTM-цикл).
2026-05-11 21:22:03	Отправка фишингового письма через DB9PR08MB6809.eurprd08.prod.outlook.com на финансовый ящик домена zenpulsar.com.
2026-05-12 09:05	HybridAnalysis автоматически отсканировал URL, snapshot Microsoft Forms сохранён через URLscan.
2026-05-12 ~13:00	Начато расследование. nam.dcv.ms/o9XDteis3W возвращает HTTP 404 — форма удалена. Все фишинговые домены остаются живыми.

3. Письмо-приманка

3.1. Заголовки и аутентификация

Письмо прошло через легитимный исходящий путь Microsoft 365 (DB9PR08MB6809.eurprd08 → GV1PR08MB8132 → AM0PR83CU005.outbound → mail-westeuropeazlp170100001, IPv6 2a01:111:f403:c201::1). Этот маршрут идентичен отправке из настоящего ящика UNAPEI в европейском регионе M365. Message-ID формата DB9PR08MB6809...@eurprd08.prod.outlook.com выдаётся исключительно Exchange Online при реальной отправке из аккаунта.

- SPF: у домена unapei-ar.fr есть корректная запись (включает spf.protection.outlook.com ~all) — результат «none» на Google MX связан с особенностью конкретного пути доставки, а не с подделкой.
- DKIM: none на Google MX — подпись DKIM для unapei-ar.fr не была передана на хопе Microsoft → Google; это ошибка конфигурации DNS UNAPEI, не спуфинг.
- DMARC: v=DMARC1; p=none — политика не применяет никаких мер, только мониторинг.

Совокупность всех признаков подтверждает: это компрометация аккаунта (АТО), а не подделка адреса.

3.2. Thread hijacking и социальная инженерия

Атакующий извлёк из взломанного ящика реальную переписку: обмен на французском языке между сотрудниками UNAPEI о медицинской теме, датированный мартом 2026 года. Эта переписка вставлена дословно под фишинговым текстом — намеренная техника для создания контекстной легитимности и включения безопасных ключевых слов, сбивающих контентные классификаторы.

- Фишинговое тело — на английском, вложенная переписка — на французском: несоответствие языков, заметное внимательному получателю.
- Поддельная подпись приписывает владельцу скомпрометированного ящика роль «Chief Financial Officer (CFO)» — в действительности это не финансовый директор. Повышение роли нацелено на обоснование финансового запроса АСН.
- Финансовая приманка: «Please find attached the ACH submission related to the completed balance settlement... REVIEW CONFIRMATION AND STATEMENT» — типичный скрипт BEC / мошенничества с банковскими переводами.

4. Первая стадия: злоупотребление Microsoft Customer Voice (nam.dcv.ms)

Единственная ссылка в теле письма — «REVIEW CONFIRMATION AND STATEMENT» — ведёт через nam.dcv.ms/o9XDteis3W, легитимный URL-шортенер Microsoft для продукта Customer Voice (Forms Pro). Этот домен находится в белых списках практически всех корпоративных решений URL-фильтрации.

Параметр	Значение
Короткий URL	hxxps://nam[.]dcv[.]ms/o9XDteis3W
Разворачивается в	hxxps://customervoice[.]microsoft[.]com/Pages/ResponsePagid=gKJ6Dz...
Заголовок формы	«A SECURED FILED HAS BEEN SUCCESSFULLY SHAF WITH YOU!»
Скомпрометированный тенант M365	unapei-ap.fr (идентификаторы доступны MSRC по запросу)
Создана	2026-05-11 14:50:51 UTC
Изменена	2026-05-11 14:54:26 UTC
Статус на момент расследования	HTTP 404 — удалена Microsoft или атакующим

Текст вопроса в форме: «Dated: Fri, May 2026». Единственный CTA — «CLICK HERE TO FULL REPORTS», ведущий на hxxps://stiofidri[.]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/.

По данным URLscan, этот паттерн злоупотребления Customer Voice активен с мая 2025 года: зафиксировано более 100 сканирований nam.dcv.ms-ссылок на нескольких языках (английский, немецкий, испанский, индонезийский) с темами

«New PDF Document Received», «Payment Advice Note», «Electronic Funds Transfer Notification». Это долгосрочная многоязычная кампания глобального охвата.

5. Вторая стадия: AiTM-кит Tusoon 2FA / Mamba 2FA

5.1. Инфраструктура

Параметр	Значение
Хост-домен	stiofidri[.]company
IP-адрес	198[.]23[.]210[.]61
ASN	AS36352 — ColoCrossing / RackNerd LLC, Чикаго, США
TLS-сертификат	Let's Encrypt R13, выдан 2026-04-17, действует до 2026-07-16
CDN	Cloudflare (CF-RAY 9fa9e25929336872-NRT)
Веб-сервер	Nginx 1.18.0 на Ubuntu
Бэкенд	Laravel (куки: XSRF-TOKEN, laravel_session, samesite=none)
NS	a.dnspod.com / b.dnspod.com / c.dnspod.com (Tencent DNSPod)

5.2. Слои защиты от анализа

Кит использует два механизма обхода автоматического анализа до отображения payload:

- CAPTCHA-шлюз: поддельный экран «Human Check / Verify identity» в стиле Gmail. Пользователь должен ввести динамически генерируемый 5-символьный код. Это блокирует автоматические сканеры, неспособные решить CAPTCHA.
- Фильтр облачных/хостинговых IP: после правильного ввода CAPTCHA кит обращается к api.ipapi.is для проверки ASN посетителя. Если ASN принадлежит любому хостинг-провайдеру (AWS, Google, Microsoft, Cloudflare, OVH, Hetzner, DigitalOcean, Linode, Akamai, Fastly, AS13335, Leaseweb, M247, LSN), браузер тихо перенаправляется на www.meituan.com (нейтральная китайская платформа). Логика фильтра XOR-обфусцирована (ключ: 3HO3y7Soso1HgJPsnDn2pg==, base64), строки блок-листа хранятся в перевёрнутом виде.

5.3. Этап кражи учётных данных (AiTM)

Посетители, прошедшие оба фильтра, видят переходный экран «Verifying your session... Validating email address...». Это характерный признак AiTM-кита: бэкенд атакующего одновременно выполняет реальные запросы аутентификации к IdP жертвы (Google Workspace или Microsoft 365), передавая введённые учётные данные и получая сессионные куки, валидные даже после прохождения MFA. Похищенные куки позволяют захватить аутентифицированную сессию без знания или обхода MFA.

5.4. Кластер инфраструктуры

Все семь фишинговых доменов используют идентичный DNS (DNSPod NS), один IP-адрес (198.23.210.61) и сертификаты Let's Encrypt, выданные в один день — 17 апреля 2026 года. Это единый PaaS-оператор, развернувший несколько доменов для параллельных кампаний или ротации при компрометации отдельного домена.

Домен	Выдан cert	NS
stiofidri[.]company	2026-04-17	a/b/c.dnspod.com
giochogio[.]company	2026-04-17	a/b/c.dnspod.com
crepeawi[.]business	2026-04-17	a/b/c.dnspod.com
crivesha[.]company	2026-04-17	a/b/c.dnspod.com
driocriodio[.]app	2026-04-17	a/b/c.dnspod.com
beawoushoo[.]digital	2026-04-17	a/b/c.dnspod.com
shodiothai[.]enterprises	2026-04-17	a/b/c.dnspod.com

6. Индикаторы компрометации (ИОС)

6.1. Сеть — вредоносные (блокировать)

Тип	Значение	Примечани
IP	198[.]23[.]210[.]61	RackNerd/Cc AS36352 — фишинг VP? доменов
Domain	stiofidri[.]company	Фишинг-кит блокировать
Domain	giochogio[.]company	Кластер — блокировать
Domain	crepeawi[.]business	Кластер — блокировать
Domain	crivesha[.]company	Кластер — блокировать
Domain	driocriodio[.]app	Кластер — блокировать
Domain	beawoushoo[.]digital	Кластер — блокировать
Domain	shodiothai[.]enterprises	Кластер — блокировать
URL	hxxps://stiofidri[.]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/	Payload URI кампании

6.2. Сеть — скомпрометированные (уведомить, не блокировать)

Тип	Значение	Примечание
Domain	unapei-ap[.]fr	Легитимная французская НКО — ящик скомпрометирован,

URL	hxxps://nam[.]dcv[.]ms/o9XDteis3W	уведомить IT организации, не блокировать Microsoft Customer Voice (форма 404) — алерт, не блокировать домен целиком
-----	-----------------------------------	--

6.3. Fingerprints фишинг-кита

Индикатор	Значение
XOR-ключ (base64)	3HO3y7Soso1HgJPsnDn2pg==
API обнаружения sandbox	api[.]ipapi[.]is
Десю-редирект	www[.]meituan[.]com
Паттерн URL-пути	/u@<случайный токен>/
Fingerprint бэкенда	Laravel (XSRF-TOKEN, laravel_session; samesite=none)
Title страницы (mid-flow)	«Verifying your session... Validating email address...»
Стиль CAPTCHA	Поддельный Gmail / Google identity check
Опечатка в title формы	«FILED» вместо «FILE» — повторяющаяся ошибка оператора

7. MITRE ATT&CK

ID	Техника	Наблюдение
T1583.001	Acquire Infrastructure: Domains	7 disposable-доменов зарегистрированы за ~3 недели до атаки
T1583.004	Acquire Infrastructure: Server	RackNerd VPS 198.23.210.61 как PaaS-фронт
T1586.002	Compromise Accounts: Email Accounts	АТО М365-ящика в домене unapei-ap.fr
T1078.004	Valid Accounts: Cloud Accounts	Настоящий М365-аккаунт для отправки и создания Customer Voice форм
T1566.002	Phishing: Spearphishing Link	Целевое письмо с вложенным URL на финансовый ящик zenpulsar.com
T1566.003	Phishing: Spearphishing via Service	Microsoft Customer Voice (nam.dcv.ms) как доверенный промежуточный

T1656	Impersonation	Владелец ящика ложно представлен как «CFO» для обоснования финансового запроса
T1036.005	Masquerading: Match Legitimate Name	nam.dcv.ms / Microsoft Forms для обхода URL-фильтрации
T1027.013	Obfuscated Files: Encrypted/Encoded File	XOR-обфусцированный JS с base64-ключом в фишинг-ките
T1497.001	Virtualization/Sandbox Evasion: System Checks	Проверка через api.ipapi.is перед раскрытием payload
T1480	Execution Guardrails	CAPTCHA-шлюз перед второй стадией
T1539	Steal Web Session Cookie	AiTM-кит похищает сессионные куки для обхода MFA
T1056.003	Input Capture: Web Portal Capture	Поддельная страница входа Gmail/Google
T1114.002	Email Collection: Remote Email Collection	Реальный тред из ящика жертвы внедрён как контекст

8. Рекомендации

8.1. Немедленные — для UNAPEI Alpes Provence

- Сбросить пароль и отозвать все refresh/access-токены скомпрометированного ящика через Entra ID.
- Проверить журналы входов Entra ID за период апрель–май 2026: геоаномалии, успешные прохождения MFA, новые app-пароли или OAuth grants.
- Проверить правила почтового ящика — атакующий мог создать правила автопересылки или удаления уведомлений безопасности.
- Повысить политику DMARC домена unapei-ap.fr с p=none до p=quarantine (краткосрочно), затем до p=reject.
- Сообщить в Microsoft MSRC (msrc.microsoft.com/report/abuse) о скомпрометированном аккаунте; идентификаторы тенанта и пользователя доступны MSRC по запросу.

8.2. Немедленные — для отключения инфраструктуры

- Сообщить о всех 7 фишинговых доменах в Identity Digital (TLD-оператор .company, .business, .digital, .app, .enterprises): abuse@identity.digital
- Сообщить об IP 198.23.210.61 в RackNerd: abuse@racknerd.com
- Подать abuse-заявку в Cloudflare (cloudflare.com/abuse/form) — CDN всех доменов.

- Сообщить в DNSPod (Tencent): abuse@dnspod.cn — для отзыва DNS-делегирования всех 7 доменов.

8.3. Защита периметра

- Заблокировать 7 вредоносных доменов и IP 198.23.210.61 в DNS RPZ, web-проху и email-шлюзе.
- НЕ блокировать nam.dcv.ms или customervoice.microsoft.com целиком — создать правило алерта: входящее письмо от внешних отправителей с nam.dcv.ms/* и финансовыми темами (ACH, Payment, Statement, Wire, EFT, Invoice) → на проверку.
- Создать YARA/Sigma-правило для паттерна anti-analysis JS: XOR-закодированный fetch к api.ipapi.is с реверсированными строками облачных провайдеров — высокоточная сигнатура данного семейства китов.
- Добавить опечатку «FILED» (вместо «FILE») как ключевое слово в фишинговые правила — оператор стабильно воспроизводит эту ошибку.
- В Entra ID ограничить создание форм Customer Voice только авторизованными группами для снижения риска при компрометации собственного тенанта.

8.4. Обучение пользователей

- Обратит внимание на несоответствие роли: письмо от сотрудника медицинской организации с неожиданной финансовой ролью (CFO) — красный флаг.
- Объяснить, что Microsoft Forms / Customer Voice — не легитимный канал для финансовых документов; любое письмо с перенаправлением через customervoice.microsoft.com для ACH или платежа следует считать подозрительным.
- Научить пользователей замечать двуязычный паттерн thread hijacking: если цитируемая переписка на другом языке, чем верхнее сообщение, это признак подстановки контекста.

TLP:CLEAR — Этот документ может распространяться без ограничений.